

Phase D - Encryption & Misconfiguration Risk Matrix

Asset	Threat	Impact	Likelihood	Risk	Mitigation	Finding / Evidence
Bucket Data	Public Exposure	High	Medium	High	Enforce S3 Block Public Access; use least-privilege bucket/IAM policies; retain default encryption. Use SSE-KMS where stronger key control, auditability, or compliance requires it.	Default SSE-S3 encryption verified on the bucket/object. Public-read configuration represents a confidentiality risk and should be reverted immediately after an authorized lab test.

Risk conclusion: Public read access can expose sensitive bucket data to unauthenticated users. S3 Block Public Access and restrictive IAM/bucket policies are the primary controls for preventing public exposure. Encryption protects data at rest but does not prevent an authorized or publicly permitted GetObject request.